

Privacy

1. Overview

Privacy is the protection of user personal data and control over how that data is collected, stored, processed, shared, and deleted.

In system design:

Security asks **“Can unauthorized people access data?”**

Privacy asks **“Should this data be collected or used at all, and under what rules?”**

Both are related but different.

2. Personally Identifiable Information (PII)

PII = data that can identify a person directly or indirectly.

Examples:

- Full name
- Email address
- Phone number
- Home address
- Government ID
- Passport number
- Bank account details
- IP address (sometimes regulated)
- Device identifiers
- Location history

3. Why Privacy Matters

Poor privacy can cause:

- Legal penalties
- Reputation damage
- User distrust
- Data misuse
- Identity theft risk

4. Regulations (Examples)

European Union GDPR

General Data Protection Regulation.

California CCPA

California Consumer Privacy Act.

Other regions have similar laws.

5. Core Privacy Principles

None

Collect minimum data

Use only for stated purpose

Protect access

Allow deletion/export

Retain only when needed

Be transparent

6. Privacy vs Security

Topic	Privacy	Security
Focus	Proper use of data	Protection from unauthorized access
Example	Should we store location?	Can hackers steal location data?

Need both.

7. Data Minimization

Only collect what is necessary.

Bad:

None

Need newsletter signup

Collect passport + DOB + address

Good:

None

Collect email only

Less data = less risk.

8. Access Control for PII

Within organization, not everyone should access customer data.

Use:

- RBAC
- Need-to-know access
- Approval workflows
- Audit trails

Example:

None

Support agent sees masked email

Finance team sees billing data only

9. LDAP / Identity Systems

Lightweight Directory Access Protocol (LDAP) often used for enterprise identity and access control.

Helps manage:

- Employees
- Groups
- Permissions

10. Encryption in Transit

Protect data moving across networks.

Use:

None

HTTPS / TLS

mTLS internally if needed

11. Encryption at Rest

Protect stored data:

- Databases
- Backups
- File systems
- Object storage

Use key management systems.

12. Tokenization / Masking

Instead of exposing real values:

None

Email: s***@gmail.com

Card: **** * 4242

Phone: *****1234

Useful for support/admin screens.

13. Hashing for Analytics

When exact identity not needed, hash identifiers.

Example:

None

customer_id → SHA-256 hash

Then aggregate statistics without exposing raw identity.

Use carefully—hashing alone may still be reversible via linkage attacks if low-entropy data.

14. Pseudonymization vs Anonymization

Method	Meaning
Pseudonymization	Replace identity with token but re-link possible
Anonymization	Cannot reasonably re-identify person

True anonymization is harder than it sounds.

15. Data Retention Policy

Keep data only as long as necessary.

Examples:

- Logs 30 days
- Failed OTP records 7 days
- Inactive user exports after request
- Tax data per legal retention rules

Less retained data = smaller breach impact.

16. Right to Delete

Users may request deletion depending on laws/business obligations.

Need system design support for:

- DB records deletion
- Search index cleanup
- Cache invalidation
- Backup lifecycle handling
- Analytics pipelines cleanup

17. Append-Only Storage Challenge

Systems like immutable logs or data lakes store historical records.

Example platforms:

- Apache Hadoop HDFS
- Event logs

Deleting one user's records can be difficult.

18. Crypto-Shredding

Useful for append-only storage.

Flow:

None

Each customer has unique encryption key

Data encrypted using that key

Delete key → data unreadable

This effectively deletes access to their data.

Excellent design discussion point.

19. Data Export / Portability

Users may request copy of their data.

Provide:

- CSV
- JSON
- Download archive

Need secure delivery.

20. Privacy in Machine Learning

Risks:

- Training on sensitive data without consent
- Model memorization
- Inference attacks
- Bias from over-collection

Mitigations:

- Minimize features
- Use consented data
- Aggregate data
- Differential privacy (advanced topic)

21. Internal Privacy Controls

Even employees should not freely browse user data.

Use:

- Just-in-time access
- Approval requests
- Session recording for sensitive admin tools
- Alert on bulk exports

22. Auditing

Track:

- Who accessed user data
- When
- Why
- What changed
- What exported

Important for compliance and breach investigations.

23. Data Breach Mitigation

Need plan for:

- Detection
- Containment
- Key rotation
- User notification (where required)
- Forensics
- Legal/compliance workflow

24. Personalization Trade-off

More personalization often needs more data.

Example:

None

Location + history + clicks = better recommendations

But increases privacy risk.

Need business balance.

25. Common Interview Example: E-commerce

Need privacy for:

- Names
- Addresses
- Payment tokens
- Purchase history

Design:

- Encrypt sensitive fields
- Mask admin views
- Role-based access
- Delete old inactive data
- Audit support access

26. Common Mistakes

Logging passwords/tokens

Storing full card numbers unnecessarily

Broad employee DB access

No retention policy
Sharing prod data with dev environments
Collecting unnecessary PII

27. Interview Answer Framework

When asked privacy:

I'd minimize PII collection, encrypt data in transit and at rest, restrict internal access with RBAC, maintain audit logs, support deletion/export requests, define retention policies, and separate analytics data from raw identity wherever possible.

28. Trade-off Table

Decision	Better Privacy	Better Business Convenience
Minimal data collection	Yes	Less personalization
Long retention	No	Easier analytics/history
Strict access controls	Yes	More operational friction
Per-user encryption keys	Stronger deletion model	More complexity

29. Best Practices

- Privacy by design
- Default deny access
- Mask data in tools
- Separate prod/dev data
- Review retention regularly
- Use consent tracking
- Classify sensitive data
- Audit privileged access

30. Short Revision Notes

None

Privacy = Proper collection/use/protection of personal data

Need:

- Minimize PII
- Encrypt
- Restrict access
- Audit
- Retention policy
- Delete/export support